ROCKET4RPO

◆ CHECKLIST JURIDIQUE

Checklist RGPD Recrutement

Les 40 points de conformite pour proteger les donnees candidats et eviter les sanctions CNIL.

Pages : 8 **Temps :** 15 min **Date :** Avril 2026

Checklist RGPD Recrutement

Le RGPD (Reglement General sur la Protection des Donnees, UE 2016/679) s'applique a toute collecte de donnees personnelles de candidats. Les sanctions peuvent atteindre 20 millions d'euros ou 4% du chiffre d'affaires mondial. Cette checklist couvre les obligations essentielles pour un processus de recrutement conforme en France.

Avertissement : Ce document est un guide pratique de conformite. Il ne remplace pas l'avis d'un DPO ou d'un avocat specialise en protection des donnees. Les references d'articles renvoient au RGPD (UE 2016/679) et au Code du travail francais.

1. Base legale du traitement (Art. 6 RGPD)

Quelle base legale pour le recrutement ?

La CNIL recommande l'**interet legitime** (Art. 6.1.f) comme base legale principale pour le traitement des candidatures spontanees ou en reponse a une offre. Le consentement (Art. 6.1.a) n'est pas adapte en raison du desequilibre entre le candidat et le recruteur.

BASE LEGALE	ARTICLE RGPD	USAGE EN RECRUTEMENT	CONDITION
Interet legitime	Art. 6.1.f	Traitement des candidatures	Test de mise en balance obligatoire
Mesures precontractuelles	Art. 6.1.b	Verification des diplomes, prise de references	A la demande du candidat
Consentement	Art. 6.1.a	Constitution du vivier (conservation post-process)	Libre, specifique, eclaire, univoque
Obligation legale	Art. 6.1.c	Verifications reglementaires (casier, habilitations)	Metiers reglementes uniquement

- [ ] La base legale du traitement est identifiee et documentee pour chaque finalite
- [ ] Un test de mise en balance des interets a ete realise (interet employeur vs droits candidat) si la base est l'interet legitime
- [ ] Le consentement est utilise uniquement pour le vivier de candidats (conservation au-dela du process de recrutement)
- [ ] Le consentement est recueilli via un formulaire dedie, distinct du formulaire de candidature
- [ ] Le consentement est libre (pas de case pre-cochee), specifique, eclaire et univoque (Art. 7)

2. Information des candidats (Art. 13 et 14 RGPD)

L'article 13 impose une information complete du candidat au moment de la collecte directe. L'article 14 s'applique lorsque les donnees sont obtenues indirectement (sourcing LinkedIn, cooptation).

Mentions obligatoires (Art. 13.1 et 13.2)

#	INFORMATION REQUISE	REF. RGPD	CONFORME
1	Identite et coordonnees du responsable de traitement	Art. 13.1.a	
2	Coordonnees du DPO (si designe)	Art. 13.1.b	
3	Finalites du traitement et base legale	Art. 13.1.c	
4	Interets legitimes poursuivis (si Art. 6.1.f)	Art. 13.1.d	
5	Destinataires ou categories de destinataires	Art. 13.1.e	
6	Transfert hors UE et garanties appropriees	Art. 13.1.f	
7	Duree de conservation ou criteres de determination	Art. 13.2.a	
8	Droits des candidats (acces, rectification, effacement, etc.)	Art. 13.2.b	
9	Droit de retrait du consentement (si applicable)	Art. 13.2.c	
10	Droit de reclamation aupres de la CNIL	Art. 13.2.d	
11	Caractere obligatoire ou facultatif de la fourniture des donnees	Art. 13.2.e	
12	Existence d'une decision automatisee ou profilage	Art. 13.2.f	

- ☐ Une politique de confidentialite candidat est redigee et accessible sur le site carriere
- ☐ L'information est fournie au moment de la collecte (formulaire, offre d'emploi)

- [ ] En cas de sourcing (LinkedIn, GitHub), le candidat est informe dans le premier message (Art. 14.3 : delai max 1 mois)
- [ ] Les mentions legales sont presentes sur chaque formulaire de candidature

3. Donnees collectees — Principe de minimisation (Art. 5.1.c)

Seules les donnees adequates, pertinentes et limitees a ce qui est necessaire au regard des finalites pour lesquelles elles sont traitees doivent etre collectees.

DONNEE	COLLECTE AUTORISEE	CONDITION
DONNEES D'IDENTIFICATION		
Nom, prenom	Oui	Necessaire
Email, telephone	Oui	Contact candidat
Adresse postale	Oui (si pertinent)	Mobilite / zone geographique
Photo	Deconseille	Non pertinent sauf metiers de representation
DONNEES PROFESSIONNELLES		
CV, lettre de motivation	Oui	Evaluation des competences
Experience professionnelle	Oui	En lien avec le poste
Formation, diplomes	Oui	Si requis pour le poste
Pretentions salariales	Oui	Adequation budget
Disponibilite, preavis	Oui	Planification embauche
Permis de conduire	Oui si justifie	Poste necessitant un vehicule
DONNEES INTERDITES (ART. 9 — DONNEES SENSIBLES)		
Numero de securite sociale	INTERDIT	Uniquement apres embauche
Situation familiale, grossesse	INTERDIT	Art. L1132-1 Code du travail
Religion, opinions politiques	INTERDIT	Art. 9.1 RGPD
Origine ethnique	INTERDIT	Art. 9.1 RGPD

Etat de sante	INTERDIT	Competence medecin du travail
Appartenance syndicale	INTERDIT	Art. 9.1 RGPD
Casier judiciaire	INTERDIT (sauf exception)	Metiers reglementes uniquement

- [ ] Les formulaires de candidature ne contiennent pas de champs non pertinents (age, situation familiale, nationalite)
- [ ] Les notes d'entretien ne contiennent aucun commentaire discriminatoire ou donnee sensible
- [ ] Un audit annuel des champs collectes est realise

4. Duree de conservation (Art. 5.1.e et Art. 17)

Recommandation CNIL : Les donnees des candidats non retenus doivent etre supprimees au plus tard **24 mois** apres le dernier contact, sauf consentement explicite pour une duree plus longue (deliberation CNIL n2002-17).

SITUATION	DUREE MAXIMALE	BASE LEGALE	ACTION REQUISE
Candidature en cours de process	Duree du recrutement	Interet legitime	Suppression a la cloture du poste
Candidat non retenu	24 mois max	Interet legitime	Suppression automatique ou manuelle
Vivier avec consentement	24 mois renouvelables	Consentement (Art. 6.1.a)	Renouvellement explicite avant expiration
Candidat embauche	Duree du contrat + 5 ans	Obligation legale	Transfert vers dossier RH
Donnees de recrutement archivees	5 ans	Art. 2224 Code civil	Archivage intermediaire securise

- [ ] Une politique de purge automatique est parametree dans l'ATS (suppression a 24 mois)
- [ ] Les candidats sont informes de la duree de conservation dans la politique de confidentialite
- [ ] Un process de renouvellement du consentement est en place pour le vivier (email de reconfirmation)
- [ ] Les CV imprimes sont detruits par broyage apres numerisation (Art. 5.1.f)
- [ ] Un registre de suppression est tenu (date, volume, methode)

5. Droits des candidats (Art. 15 a 22)

DROIT	ARTICLE	DELAI DE REPONSE	MODALITE
Droit d'acces	Art. 15	1 mois	Copie des donnees en format lisible
Droit de rectification	Art. 16	1 mois	Correction des donnees inexactes
Droit a l'effacement	Art. 17	1 mois	Suppression si plus de base legale
Droit a la limitation	Art. 18	1 mois	Gel du traitement en cas de contestation
Droit a la portabilite	Art. 20	1 mois	Export en format structure (CSV, JSON)
Droit d'opposition	Art. 21	1 mois	Opposition au traitement (interet legitime)
Decision individuelle automatisee	Art. 22	1 mois	Droit a une intervention humaine

- ☐ Un processus interne est en place pour traiter les demandes dans le delai legal (1 mois, prolongeable de 2 mois si complexe)
- ☐ Les coordonnees pour exercer les droits sont publiees dans la politique de confidentialite
- ☐ Un registre des demandes d'exercice de droits est tenu
- ☐ L'identite du demandeur est verifiee avant communication des donnees

6. Securite des donnees (Art. 32)

Le responsable de traitement et le sous-traitant doivent mettre en oeuvre les mesures techniques et organisationnelles appropriees pour garantir un niveau de securite adapte au risque.

- ☐ Les CV et donnees candidats sont stockes dans un systeme securise (ATS, espace chiffre)
- ☐ L'acces aux donnees est limite aux personnes habilitees (recruteurs, hiring managers du poste concerne)
- ☐ L'authentification forte est activee sur l'ATS (MFA / 2FA)
- ☐ Les mots de passe respectent les recommandations CNIL 2022 (12 caracteres min, complexite)
- ☐ Les echanges de CV par email sont limites — le partage via ATS est privilegie
- ☐ Aucun CV n'est stocke sur des espaces partages non securises (Google Drive public, Slack, WhatsApp)
- ☐ Les postes de travail accedant aux donnees candidats disposent d'un antivirus a jour et d'un chiffrement disque
- ☐ Un registre des violations de donnees est tenu (Art. 33 : notification CNIL sous 72h en cas de violation)

7. Sous-traitants et transferts (Art. 28 et Art. 44-49)

Contrats sous-traitants (Art. 28)

Tout sous-traitant qui traite des donnees candidats pour votre compte doit etre encadre par un contrat incluant les clauses de l'Art. 28.3.

- [ ] Un registre des sous-traitants traitant des donnees candidats est a jour

- [ ] Des clauses RGPD (Art. 28.3) sont incluses dans les contrats avec :

SOUS-TRAITANT	DONNEES TRAITEES	CLAUSE ART. 28	TRANSFERT HORS UE
ATS / logiciel de recrutement	CV, identite, historique candidature		
Cabinets de recrutement / RPO	CV, notes d'entretien, evaluations		
Plateformes de tests / assessments	Resultats, identite		
Outils de visioconference	Enregistrements (si applicable)		
Outils d'emailing / CRM candidat	Email, prenom, historique echanges		
Outils d'IA (ChatGPT, Claude, etc.)	Donnees saisies dans les prompts		

- [ ] En cas de transfert hors UE : clauses contractuelles types (CCT) ou decision d'adequation (Art. 45)

- [ ] Les sous-traitants americains sont encadres par le EU-US Data Privacy Framework ou des CCT (Art. 46)

- [ ] Aucune donnee candidat n'est copiee dans un outil d'IA sans anonymisation prealable

8. IA et recrutement (AI Act + RGPD)

AI Act europeen (Reglement UE 2024/1689) : Les systemes d'IA utilises dans le recrutement sont classes **"haut risque"** (Annexe III, point 4). Ils sont soumis a des obligations renforcees : evaluation de conformite, gestion des risques, transparence, supervision humaine et documentation technique.

- ☐ Les outils d'IA utilises dans le recrutement sont documentes (registre des traitements + registre AI Act)
- ☐ Une analyse d'impact (AIPD / DPIA, Art. 35) est realisee si traitement automatise a grande echelle
- ☐ Les candidats sont informes de l'utilisation d'outils automatises (Art. 13.2.f et Art. 22)
- ☐ Une intervention humaine est garantie dans la decision finale de recrutement (Art. 22.3)
- ☐ Les biais algorithmiques sont audites au moins une fois par an
- ☐ Les donnees candidats ne sont pas utilisees pour entrainer des modeles d'IA sans consentement

9. Registre des traitements (Art. 30)

Toute entreprise de 250+ salaries ou tout responsable de traitement dont le traitement est susceptible de comporter un risque pour les droits et libertes des personnes doit tenir un registre.

ELEMENT DU REGISTRE	EXEMPLE RECRUTEMENT
Finalite du traitement	Gestion des candidatures et recrutement de collaborateurs
Categories de personnes	Candidats (externes et internes)
Categories de donnees	Identite, CV, notes d'entretien, evaluations, references
Destinataires	Equipe recrutement, hiring managers, sous-traitants (ATS, outils)
Duree de conservation	24 mois apres dernier contact (candidats non retenus)
Mesures de securite	Chiffrement, controle d'acces, MFA, pseudonymisation
Transferts hors UE	Oui/Non — si oui, garanties (CCT, adequation, EUUS DPF)

- ☐ Le traitement "recrutement" est inscrit au registre des traitements
- ☐ Le registre est mis a jour au moins une fois par an ou a chaque changement d'outil
- ☐ Le registre est accessible au DPO et a la CNIL en cas de controle

10. Modele de formulaire de consentement (vivier)

Modele de clause consentement vivier :

"J'autorise [Nom de l'entreprise] a conserver mes donnees personnelles (CV, coordonnees, notes d'entretien) dans son vivier de candidats pour une duree de 24 mois a compter de ce jour, dans le but d'etre recontacte(e) pour des opportunites correspondant a mon profil. Je comprends que je peux retirer ce consentement a tout moment en ecrivant a [email DPO/recrutement]. Ce retrait n'affectera pas la liceite du traitement effectue avant le retrait."

Signature : _____ **Date :** __ / __ / ____

11. Checklist DPO — 10 points de controle annuel

40	24 mois	72h
POINTS DE CONFORMITE	CONSERVATION MAX CNIL	DELAI NOTIFICATION VIOLATION

- [ ] Le registre des traitements "recrutement" est a jour (Art. 30)
- [ ] Les politiques de confidentialite candidat sont publiees et accessibles
- [ ] Les durees de conservation sont respectees — purge effectuee
- [ ] Les contrats sous-traitants incluent les clauses Art. 28
- [ ] Les outils d'IA sont documentes (AI Act) et les candidats informes
- [ ] Les demandes d'exercice de droits ont ete traitees dans les delais (registre a jour)
- [ ] Les mesures de securite sont adequates (audit annuel)
- [ ] Les formulaires de candidature ont ete audites (minimisation des donnees)
- [ ] Les hiring managers sont formes aux bonnes pratiques RGPD (au moins 1x/an)
- [ ] Aucune violation de donnees non signalee n'est identifiee

Synthese : les 10 reflexes RGPD du recruteur

1. **Informer** le candidat des la collecte (Art. 13)
2. **Minimiser** : ne collecter que les donnees necessaires (Art. 5.1.c)
3. **Supprimer** les donnees apres 24 mois (recommandation CNIL)
4. **Securiser** le stockage des CV (Art. 32)
5. **Limiter** l'acces aux personnes habilitees
6. **Consentir** : obtenir un consentement explicite pour le vivier (Art. 6.1.a)
7. **Repondre** aux demandes d'acces sous 1 mois (Art. 12.3)
8. **Encadrer** les sous-traitants par contrat (Art. 28)
9. **Documenter** l'utilisation d'outils d'IA (AI Act)
10. **Former** les hiring managers aux bonnes pratiques RGPD

ROCKET4RPO

rocket4rpo.com — Tous droits reserves 2026

Donnees issues de 200+ recrutements realises